

Informe de Pruebas de Penetración

My File Server — 1 | Resultados para el Consejo Directivo

Nivel de riesgo global: **CRÍTICO**

Presentación ejecutiva de hallazgos y plan de remediación

Contexto del Engagement

01

OBJETIVO EVALUADO

My File Server — 1
(192.168.56.103)

02

ENTORNO DE PRUEBA

Laboratorio controlado
(imagen VulnHub)

03

PLATAFORMA DE ATAQUE

Kali Linux
(192.168.56.101)

04

ENFOQUE

Caja negra, sin
ingeniería social

Alcance autorizado

- Reconocimiento y enumeración de servicios
- Explotación controlada de vulnerabilidades
- Escalada de privilegios y cadena de ataque
- Análisis de impacto bajo el modelo C.I.A.

Fuera de alcance

- Sistemas distintos a My File Server — 1
- Ingeniería social o phishing a personal
- Pruebas con intenciones destructivas
- Exfiltración de datos fuera del laboratorio

Entregables: informe técnico, tabla de hallazgos con evidencia y capturas del desarrollo metodológico.

Metodología Aplicada



Plataforma y herramientas

Atacante: Kali Linux. Objetivo: My File Server — 1 (CentOS). Herramientas: arp-scan, Nmap, Nikto, SMBMap, cliente FTP, OpenSSH/ssh-keygen, GCC y exploit público de CVE-2016-5195.

Enfoque: simulación de un atacante real dentro de un entorno virtual hermético, documentando cada fase de forma reproducible.

Nivel General del Riesgo

RIESGO DEL ACTIVO

CRÍTICO

Acceso anónimo a servicios de red escaló hasta control total del sistema (root).

CADENA DE COMPROMISO

→ Credencial expuesta en readme.txt

→ Acceso FTP/SSH como smbuser

→ Explotación de Dirty COW (kernel)

→ Control total como root



7 hallazgos totales — 1 crítico y 3 altos requieren acción inmediata.

Impacto C.I.A.: Confidencialidad e Integridad en nivel Crítico; Disponibilidad en nivel Alto.

Hallazgos Críticos

F-07

Escalada de privilegios vía Dirty COW (CVE-2016-5195)

CRÍTICA

Kernel desactualizado permitió obtener consola root desde el usuario smbuser.

F-01

Credencial expuesta en archivo público (readme.txt)

ALTA

Contraseña en texto plano accesible desde el servicio web, origen del vector de entrada.

F-04

Sesión nula SMB con escritura habilitada (smbdata)

ALTA

Acceso no autenticado de lectura/escritura; sin firma de mensajes SMB.

F-03

Persistencia SSH vía subida de llave pública por FTP

ALTA

Home de usuario escribible permitió instalar authorized_keys sin credenciales repetidas.

Escenario del Impacto Empresarial

Confidencialidad

CRÍTICO

Acceso total a archivos y datos alojados en el servidor, sin restricción alguna una vez obtenido el root.

Integridad

CRÍTICO

Modificación de archivos críticos del sistema (/usr/bin/passwd) y creación de accesos no autorizados (.ssh).

Disponibilidad

ALTO

El acceso root permite detener servicios o eliminar datos, afectando la continuidad del servicio de archivos.

Lectura para el negocio

- Pérdida de datos de clientes o internos almacenados en el servidor de archivos
- Interrupción del servicio de archivos y de las operaciones que dependen de él
- Riesgo de persistencia encubierta (acceso SSH) no detectado por controles actuales
- Exposición reputacional y regulatoria ante una eventual fuga de información

Matriz de Riesgo

ID	Hallazgo	Severidad	Recurso afectado
F-07	Escalada de privilegios — Dirty COW	Crítica	Sistema operativo (kernel)
F-01	Credencial expuesta en readme.txt	Alta	Servicio web
F-04	Sesión nula SMB con escritura	Alta	Recurso smbdata
F-03	Persistencia SSH vía FTP	Alta	Cuenta smbuser
F-02	FTP anónimo y servicio duplicado	Media	Servicio FTP
F-05	Exposición de NFS / rpcbind / mountd	Media	Servicios RPC
F-06	Apache desactualizado sin cabeceras	Media	Servidor web

Las severidades Crítica y Alta concentran el riesgo del activo y son la base del plan de remediación priorizado.

Recomendaciones Estratégicas

1

Eliminar exposición de credenciales

Retirar readme.txt del webroot y rotar la contraseña de smbuser de inmediato.

2

Bastionar FTP y SMB

Deshabilitar acceso anónimo FTP, sesiones nulas SMB y forzar firma de mensajes (SMB signing).

3

Actualizar el kernel

Parchear o actualizar el sistema operativo para corregir CVE-2016-5195 (Dirty COW).

4

Endurecer el servidor web

Actualizar Apache, deshabilitar TRACE, desactivar listado de directorios y añadir cabeceras de seguridad.

5

Restringir servicios RPC/NFS

Limitar por firewall el acceso a rpcbind, NFS y mountd solo a hosts autorizados.

6

Gestión formal de parches

Establecer monitoreo de archivos sensibles (authorized_keys) y ciclo continuo de actualizaciones.

Roadmap de Remediación



Conclusión Ejecutiva

El sistema evaluado presenta un riesgo CRÍTICO: una cadena de fallas de configuración permitió escalar desde acceso anónimo hasta control total como root.

-
- ✓ 7 hallazgos documentados — 1 crítico y 3 altos de atención inmediata
 - ✓ La remediación prioritaria (0–7 días) reduce el riesgo de forma significativa
 - ✓ Se recomienda validar las correcciones con una prueba de re-test